

Actividad 11: Road to Hall Of Fame

Laboratorio: File path traversal, validation of start of path

Asignatura: Seguridad Informática

Realizado por el alumno: Manuel Darío Trejo Salazar

Herramienta utilizada: Burp Suite Community Edition

1.- Nombre del laboratorio

File path traversal, validation of start of path

URL del laboratorio:

<https://portswigger.net/web-security/file-path-traversal/lab-validate-start-of-path>

Lab: File path traversal, validation of start of path

PRACTITIONER

LAB Not solved

This lab contains a path traversal vulnerability in the display of product images.

The application transmits the full file path via a request parameter, and validates that the supplied path starts with the expected folder.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

ACCESS THE LAB

Solution

Community solutions

2.- Nivel

Practitioner (Intermedio).

Este laboratorio presenta un mecanismo de defensa basado en la validación del prefijo de la ruta. La aplicación comprueba que el input del usuario comience con el directorio esperado, pero es vulnerable porque no restringe ni valida el resto de la cadena.

3.- Tipo de explotación

File Path Traversal (Arbitrary File Read) con evasión de validación de prefijo (Path Validation Bypass).

La vulnerabilidad ocurre cuando los desarrolladores intentan asegurar el acceso a archivos requiriendo que la ruta solicitada comience con una cadena fija (por ejemplo, el directorio base de imágenes). Esto generalmente se implementa usando funciones como `startsWith()` en Java, `strpos() === 0` en PHP o `startswith()` en Python.

El fallo de seguridad radica en que verificar únicamente el inicio de la cadena no impide el uso de secuencias de recorrido (`../`) en la parte posterior de la misma. Un atacante puede proporcionar el prefijo exacto que la aplicación espera, evadiendo así la comprobación, y luego anexar secuencias de retroceso para navegar fuera de ese directorio y acceder a archivos sensibles del sistema operativo.

Consecuencias: Lectura de archivos críticos del sistema, acceso a código fuente y evasión de políticas de control de acceso basadas en nombres o rutas de directorio.

4. Objetivo del laboratorio

Demostrar la explotación de una vulnerabilidad de File Path Traversal evadiendo un filtro de validación de inicio de ruta. Esto se logra enviando la ruta base esperada por la aplicación seguida de secuencias de retroceso de directorio a través del parámetro `filename`, con el fin de leer el contenido del archivo `/etc/passwd` del servidor y obtener la confirmación de "Lab solved".

5. Explicación técnica de la vulnerabilidad

En este escenario, la tienda en línea requiere que se le pase la ruta absoluta del directorio donde residen las imágenes al cargar un producto:

GET /image?filename=/var/www/images/71.jpg HTTP/2

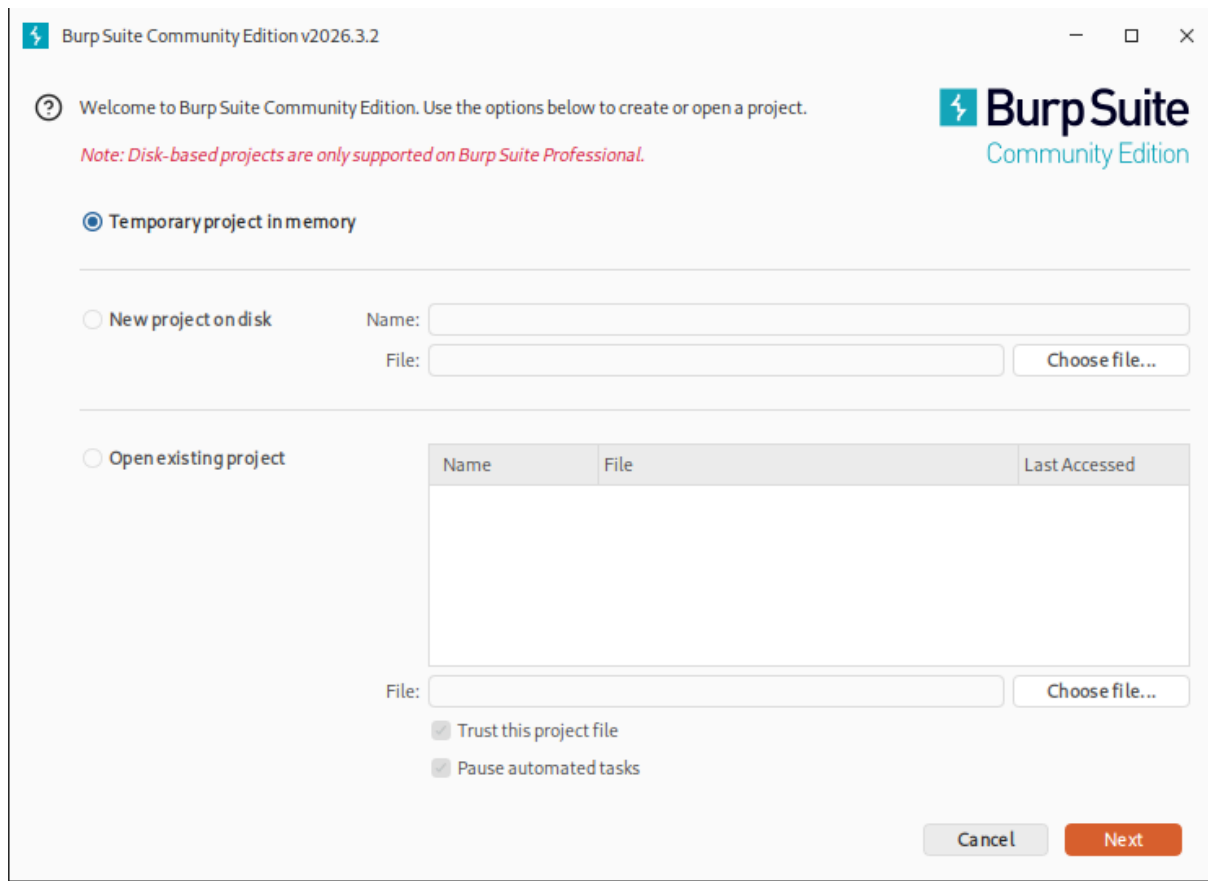
Para proteger el servidor, la aplicación implementa una validación que comprueba si el valor proporcionado por el usuario en el parámetro filename comienza exactamente con la ruta predefinida /var/www/images/.

El problema técnico es que esta validación solo inspecciona el prefijo de la entrada y asume erróneamente que, si comienza bien, toda la ruta es segura. No elimina ni bloquea las secuencias ../.

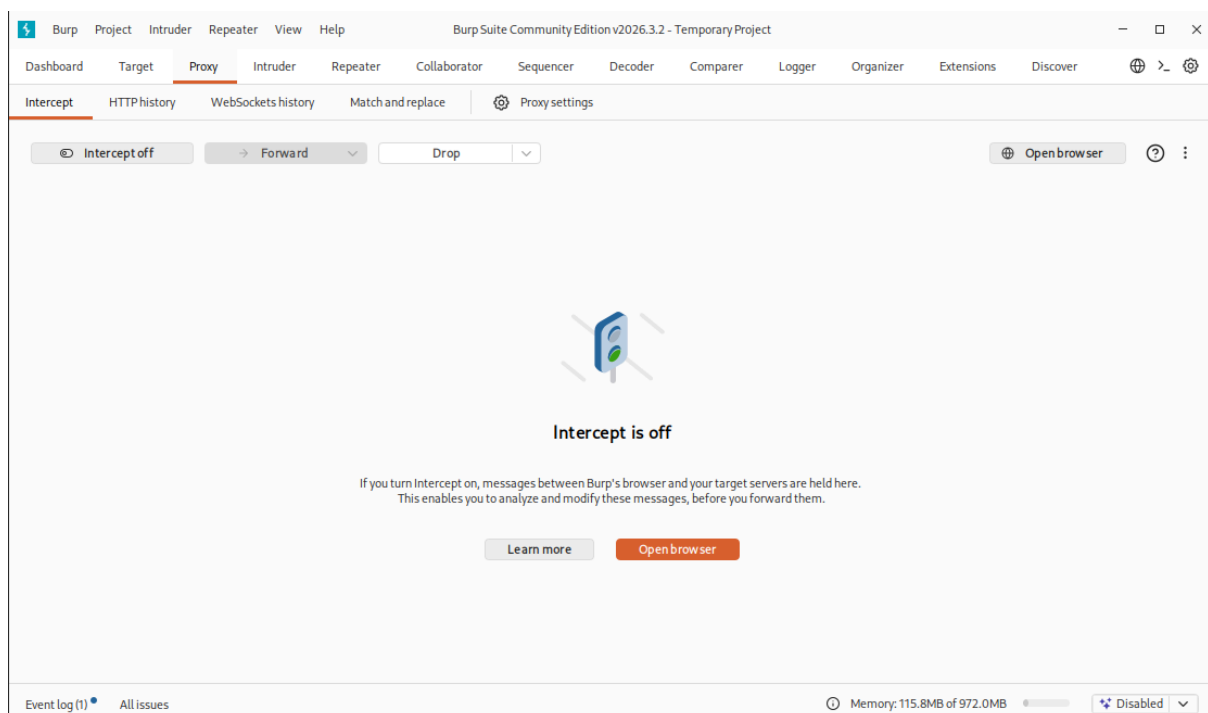
Si un atacante envía /var/www/images/../../../../etc/passwd, la aplicación aprueba la entrada porque la condición del prefijo se cumple de manera estricta (startsWith("/var/www/images/") devuelve true). Luego, al pasar esta cadena completa a las APIs del sistema de archivos, el sistema operativo resuelve dinámicamente la ruta: entra a los directorios y luego las secuencias ../ anulan el directorio base subiendo niveles hasta la raíz, terminando por resolver y devolver el archivo objetivo.

6. Procedimiento paso a paso

Se inicia Burp Suite Community Edition desde la máquina virtual, seleccionando en las configuraciones iniciales, Temporary project in memory y posteriormente Use Burp defaults.

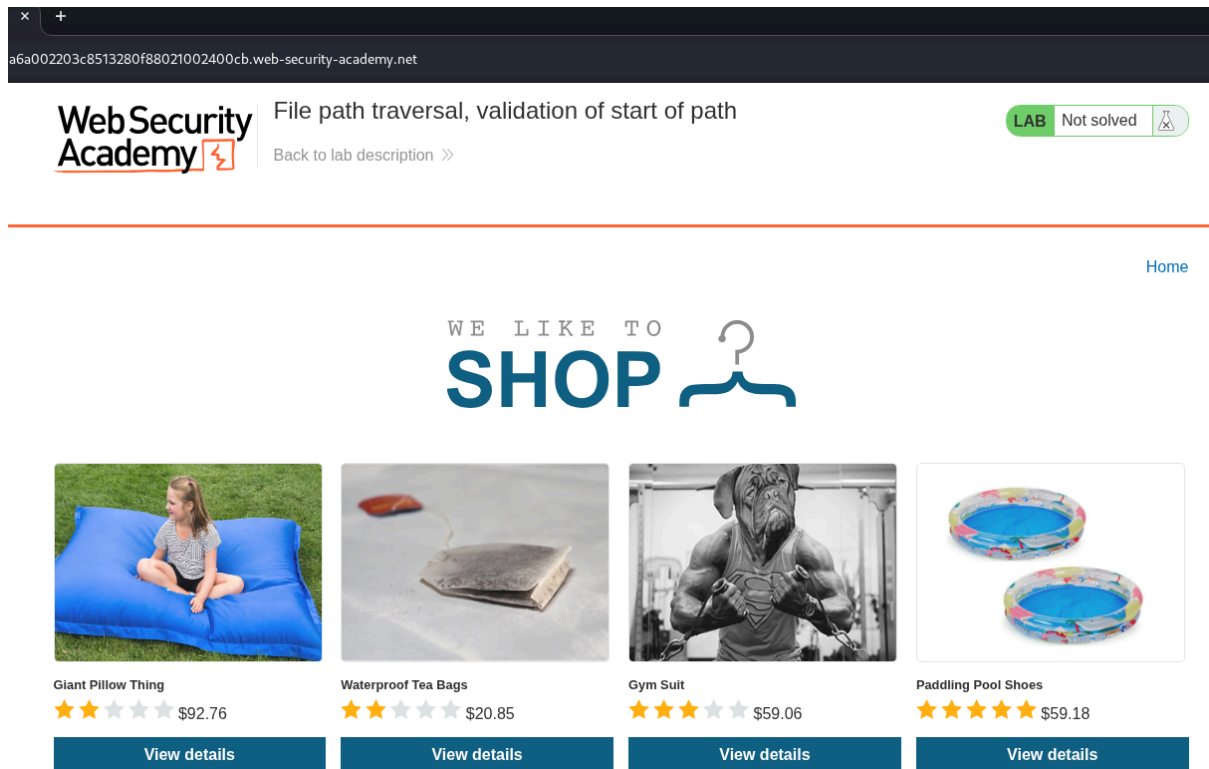


Con Burp abierto en la pestaña Proxy > Intercept, se abre el navegador integrado y se accede a la URL del laboratorio proporcionada por PortSwigger.



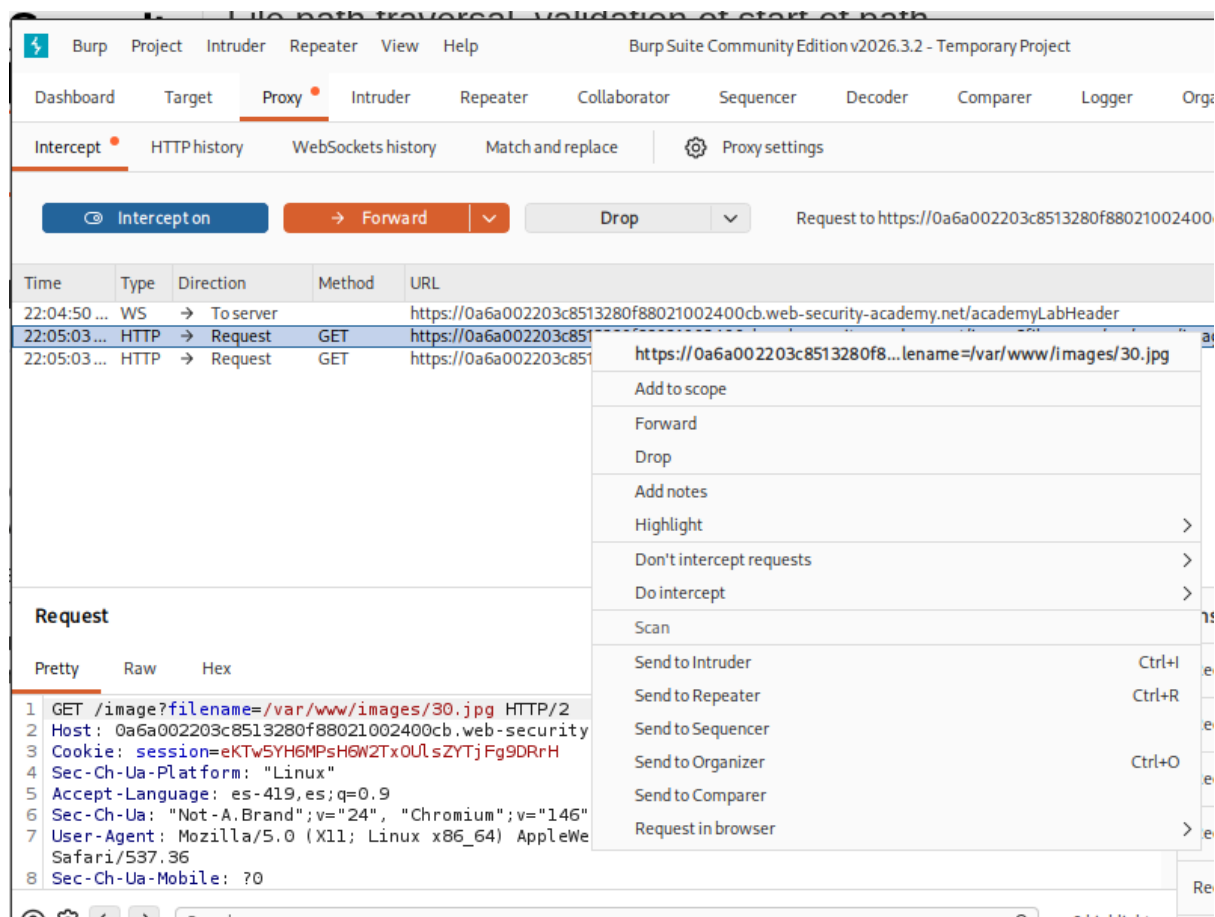
En Burp Suite se desactiva temporalmente el interceptor ("Intercept is off") para permitir la carga completa de la página de la tienda.

Se navega a la página de un producto (clic en "View details"), lo que dispara la petición que carga la imagen del producto.



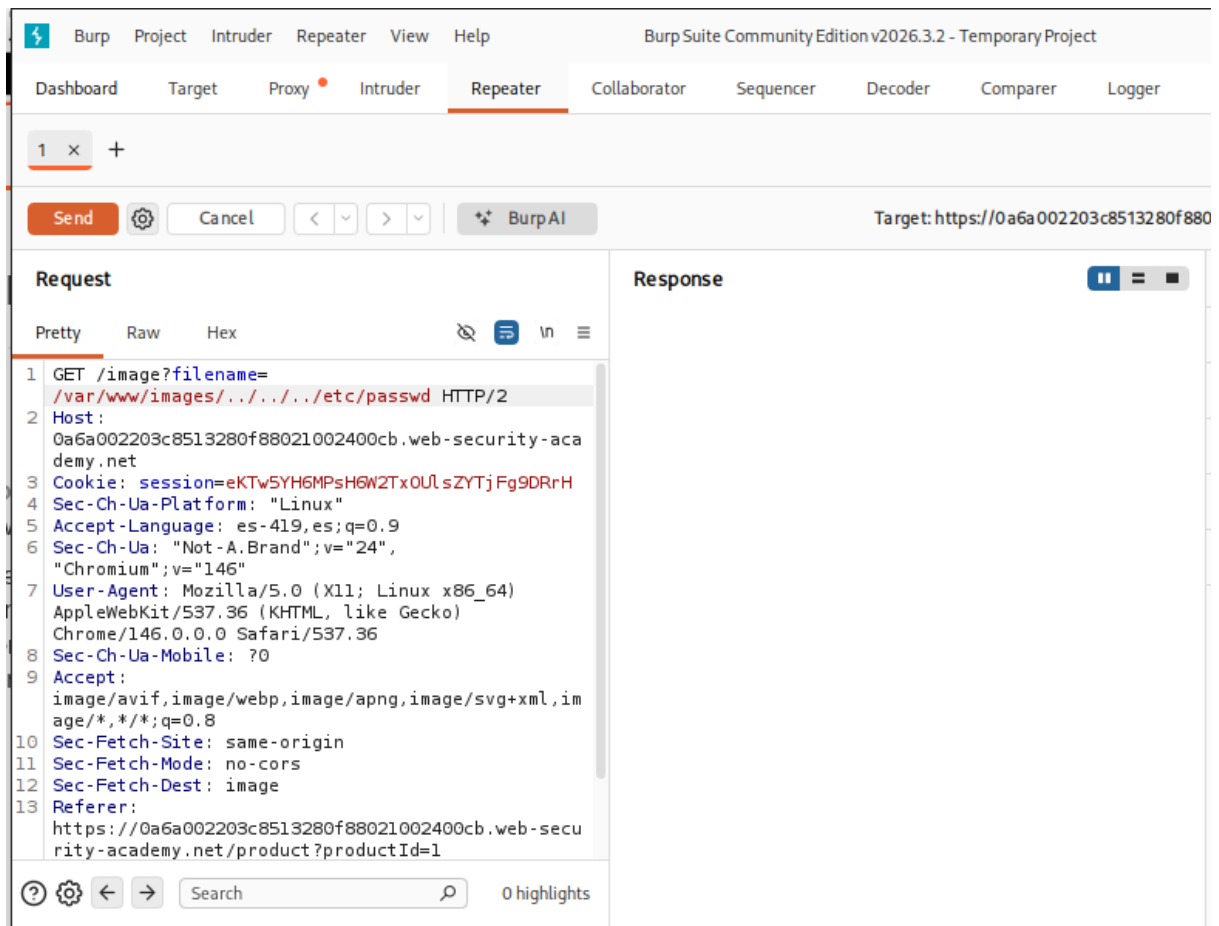
Se busca en el historial (pestaña Proxy > HTTP history) la petición GET que carga la imagen (en este caso la petición se verá similar a GET /image?filename=/var/www/images/71.jpg) y se selecciona con clic derecho → "Send to Repeater".

El módulo Repeater permite editar y reenviar la petición observando las respuestas del servidor en tiempo real.



En la línea 1 del request, dentro de la pestaña Repeater, se modifica el valor del parámetro filename, manteniendo el inicio de ruta esperado y concatenando el payload malicioso:

GET /image?filename=/var/www/images/../../../../etc/passwd HTTP/2



Se presiona "Send".

En el panel Response se observa una respuesta HTTP/2 200 OK. En el cuerpo de la respuesta se visualiza el contenido completo del archivo /etc/passwd del servidor, validando que la técnica del prefijo válido logró evadir el filtro:

Burp Suite Community Edition v2026.3.2 - Temporary Project

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Comparer Logger

1 x +

Send Cancel < > Burp AI Target: https://0a6a002203c8513280f88021002400cb.web-security-academy.net

Request

Pretty Raw Hex

```

1 GET /image?filename=
  /var/www/images/../../../../etc/passwd HTTP/2
2 Host:
  0a6a002203c8513280f88021002400cb.web-security-academy.net
3 Cookie: session=eKTw5YH6MPsH6W2Tx0ULsZYTjFg9DRrH
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24",
  "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept:
  image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer:
  https://0a6a002203c8513280f88021002400cb.web-security-academy.net/product?productId=1

```

Response

Pretty Raw Hex Render

```

1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mailing List

```

0 highlights

Se regresa a la pestaña del laboratorio en el navegador y se recarga la página (F5).

Apareció el banner verde: LAB Solved!

(Agregar captura de pantalla del banner LAB Solved - "Confirmación de Lab Solved")



File path traversal, validation of start of path

[Back to lab description >>](#)

LAB Solved

7. Explicación del payload

Payload utilizado: /var/www/images/../../../../etc/passwd

El payload consta de tres partes fundamentales que trabajan en conjunto para engañar a la aplicación y al sistema de archivos:

- `/var/www/images/` : Es el prefijo obligatorio que la aplicación exige para dar por válida la solicitud. Al incluirlo al principio, el filtro de seguridad (ej. `startsWith`) devuelve verdadero y deja pasar la petición.
- `../..../` : Son las secuencias de retroceso de directorio relativas. Una vez que la ruta base es aceptada, estas secuencias indican al sistema operativo que suba de nivel. Partiendo desde el directorio `images/`, el primer `../` sube a `www/`, el segundo a `var/` y el tercero llega directamente a la raíz del sistema de archivos `/`.
- `etc/passwd` : Es la ruta relativa desde la raíz hacia el archivo objetivo que contiene la lista de usuarios del sistema Linux, el cual es finalmente devuelto al usuario.

8. Mitigación recomendada

- Canonicalización estricta de rutas (El enfoque correcto): Validar si una cadena "comienza con" cierto texto no es una medida de seguridad válida para nombres de archivos. La aplicación debe resolver primero la ruta real del archivo (ruta canónica) utilizando APIs como `getCanonicalPath()` en Java o `realpath()` en PHP. Estas funciones obligan al sistema a resolver todos los `../` y enlaces simbólicos.
- Validación posterior a la canonicalización: Una vez obtenida la ruta canónica final y limpia, ahora sí se debe comprobar si dicha ruta comienza estrictamente con el directorio base permitido (ej. `/var/www/images/`). De esta forma, cualquier intento de escape será detectado porque la ruta real devuelta por el sistema operativo ya no comenzará con `/var/www/images/`.
- Identificadores indirectos: Evitar a toda costa que el usuario pueda interactuar o enviar rutas completas del servidor. Es mucho más seguro mapear las imágenes a un ID numérico (`?id=71`) o a un nombre de archivo simple (`?file=71.jpg`) que enviar la ruta de un directorio, restringiendo la validación a expresiones regulares (alfanuméricos + extensión).